

Stoquify Supplier Workflow Review

Generated: 2026-08-08 Requested date: 2026-08-08 Mode: conditional-pass

Scope

- `app/[locale]/(dashboard)/dashboard/purchases/suppliers/page.tsx`
- `app/[locale]/(dashboard)/dashboard/purchases/suppliers/create/page.tsx`
- `app/[locale]/(dashboard)/dashboard/purchases/suppliers/[id]/page.tsx`
- `app/[locale]/(dashboard)/dashboard/purchases/suppliers/[id]/edit/page.tsx`
- `app/[locale]/(dashboard)/dashboard/purchases/suppliers/layout.tsx`
- `actions/suppliers/supplier-management-actions.ts`
- `actions/suppliers/itemSupplierActions.ts`
- `actions/suppliers/getOrgSuppliers.ts`
- `services/supplier/supplier.service.ts`
- `services/supplier/supplier.schemas.ts`
- `components/suppliers/SupplierManagementDashboard.tsx`
- Targeted supplier tests under `app/[locale]/(dashboard)/dashboard/purchases/suppliers/__tests__`, `actions/suppliers/__tests__`, and `services/supplier/__tests__`.

Executed validation

- `npm run typecheck`  passed
- `npm run lint`  passed with 3 non-blocking warnings (image usage, default export style)
- Tests executed and passed:
 - `app/[locale]/(dashboard)/dashboard/purchases/suppliers/__tests__/page-boundary.test.tsx` (9 tests)
 - `app/[locale]/(dashboard)/dashboard/purchases/suppliers/__tests__/layout-boundary.test.tsx` (3 tests)
 - `app/[locale]/(dashboard)/dashboard/purchases/__tests__/page.test.tsx` (4 tests)
 - `app/[locale]/(dashboard)/dashboard/purchases/[id]/__tests__/page.test.tsx` (4 tests)
 - `actions/suppliers/__tests__/get-org-suppliers.test.ts` (2 tests)
 - `actions/suppliers/__tests__/itemSupplierActions.test.ts` (3 tests)
 - `services/supplier/__tests__/supplier.service.test.ts` (5 tests)

Findings

1) PII export surfaces are not redacted (Medium, supplier privacy)

The supplier dashboard export includes direct fields with customer/supplier contact data and tax identifiers:

- `components/suppliers/SupplierManagementDashboard.tsx:705-713` includes `contactPerson`, `email`, `phone`, `country`, `creditLimit`, `taxId` in CSV payload.
- `components/suppliers/SupplierManagementDashboard.tsx:681-684` enables copy of internal `supplier.id` without role-sensitive masking or signed event context.

Impact: any user with supplier-read access can trigger CSV output that includes email, phone and tax ID in clear text on local disks and browser memory. This is acceptable only if your policy explicitly treats this as authorized internal-only reporting; it is not currently documented as masked or minimized in the supplier flow.

Status: **Not blocked, but requires security-ratification decision before enterprise-grade publication.**

2) Supplier management test coverage is structurally strong but not yet complete by surface (Medium-Low)

Route-level and action-layer tests correctly assert:

- RBAC denial/fallback behavior,
- module observation call presence/absence,
- tenant scoping on action paths.

Coverage gap observed:

- No direct test currently enforces **data-minimization** for exported supplier payloads.
- No test currently validates the **delete/archival semantics** branch in service-level supplier removal beyond minimal tenant filtering.

Status: **Acceptable for workflow completeness, but remediation is recommended before claiming full hardening.**

3) Route and action boundaries are generally robust (No issue)

Good controls verified in route and service surfaces:

- Supplier route and layout guard with targeted permission checks in:
 - `app/[locale]/(dashboard)/dashboard/purchases/suppliers/page.tsx`
 - `.../create/page.tsx`
 - `.../[id]/page.tsx`
 - `.../[id]/edit/page.tsx`
 - `.../suppliers/layout.tsx`
- Item-supplier actions enforce combined permissions (`inventory.items.*` + `purchases.suppliers.*`) before write operations in `actions/suppliers/itemSupplierActions.ts`.
- Tenant scoping enforced for item-supplier writes and reads by service checks such as `itemSupplierOrgWhere`, `assertItemAndSupplierInOrganization`, and `require / assertCanUseOrganization` chains.
- No high-severity issues observed in this run.

Overall review result

- Security/compliance posture is **strong on access control and tenant isolation** for the supplier workflow.
- Missing enterprise-hardening item: **supplier data minimization on exported or exported-like outputs.**
- No blocking defects found in RBAC/module-boundary logic during this execution.